Vulnerability Assessment Report

Name: Saloni Kumari

Date: 26 April 2026

Target: OWASP Juice Shop (local host:3000)

Executive Summary

A vulnerability assessment was performed on OWASP Juice Shop running on local host port 3000. The assessment identified several security issues including missing security headers, exposed directories, and information disclosure vulnerabilities. These issues should be addressed to improve the security posture of the application.

Methodology

The following tools and techniques were used for the assessment:

Tool	**Purpose**
Nmap	Host discovery and port enumeration
Nikto	Web server vulnerability scanning
Dirsearch	Hidden files and directories discovery

Technical Findings

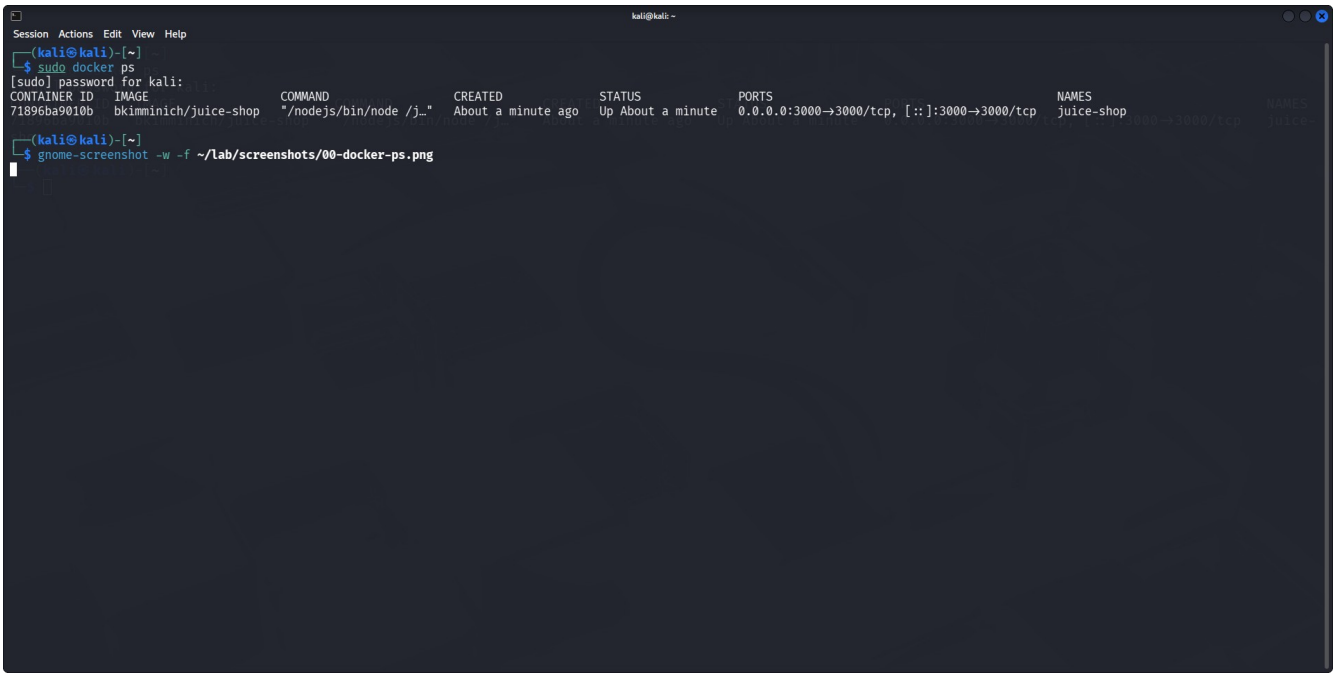
The following vulnerabilities were identified:

#	**Finding**	**Severity**	**Impact**	**Remediation**
1	Missing Content-Security-Policy header	Medium	XSS attacks possible	Add CSP header in server config
2	Missing HSTS header	Medium	SSL stripping attacks	Enable HSTS
3	/robots.txt exposed	Low	Information disclosure	Remove sensitive

#	Finding	Severity	Impact	Remediation
				entries
4	/ftp: directory accessible	Medium	File disclosure	Restrict directory access
5	/public: directory accessible	Low	Information disclosure	Restrict directory access
6	Shell history files exposed	High	Credential leakage	Remove files from web root

Screenshots:

01: Docker PS (Juice Shop running)



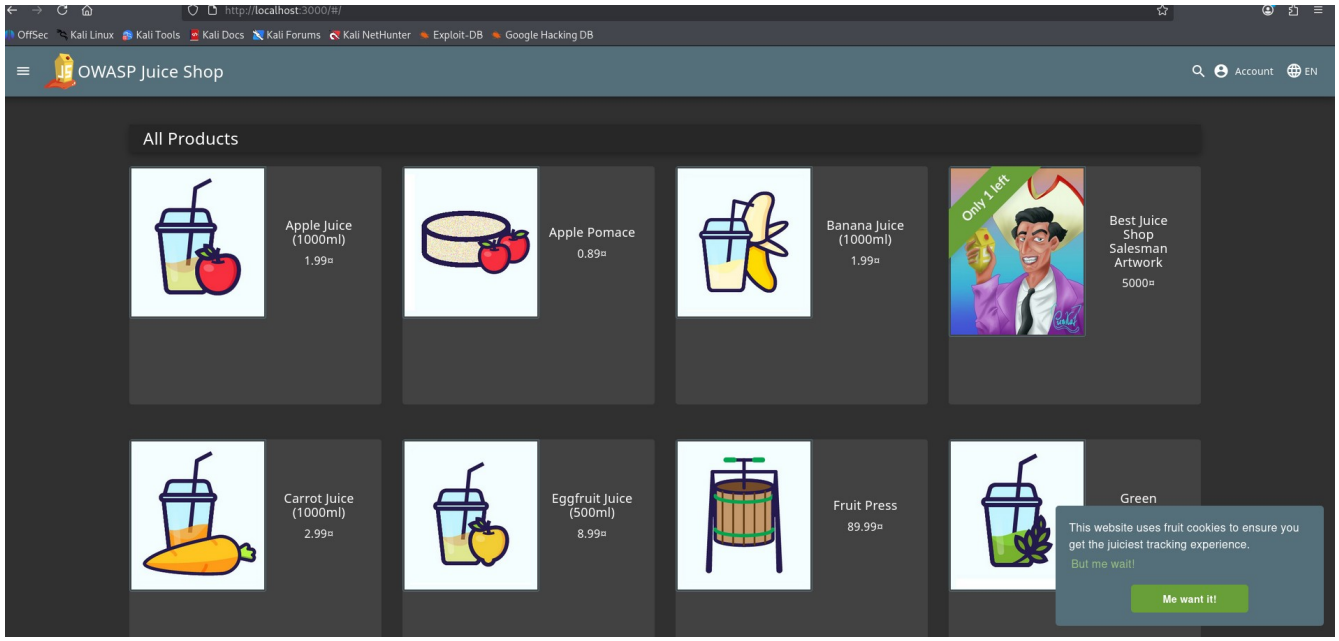
02: Host Discovery (nmap -sn)

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ sudo docker ps
[sudo] password for kali:
CONTAINER ID   IMAGE                COMMAND                  CREATED          STATUS          PORTS                                       NAMES
71896ba9010b   bkimminich/juice-shop   "/nodejs/bin/node /j…"   About a minute ago   Up About a minute   0.0.0.0:3000→3000/tcp, [::]:3000→3000/tcp   juice-shop

┌──(kali㉿kali)-[~]
└─$ gnome-screenshot -w -f ~/lab/screenshots/00-docker-ps.png
** Message: 13:43:05.136: Unable to use GNOME Shell's builtin screenshot interface, resorting to fallback X11.

┌──(kali㉿kali)-[~]
└─$ nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 13:47 EDT
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.02 seconds

┌──(kali㉿kali)-[~]
└─$ gnome-screenshot -w -f ~/lab/screenshots/01-host-discovery.png
```

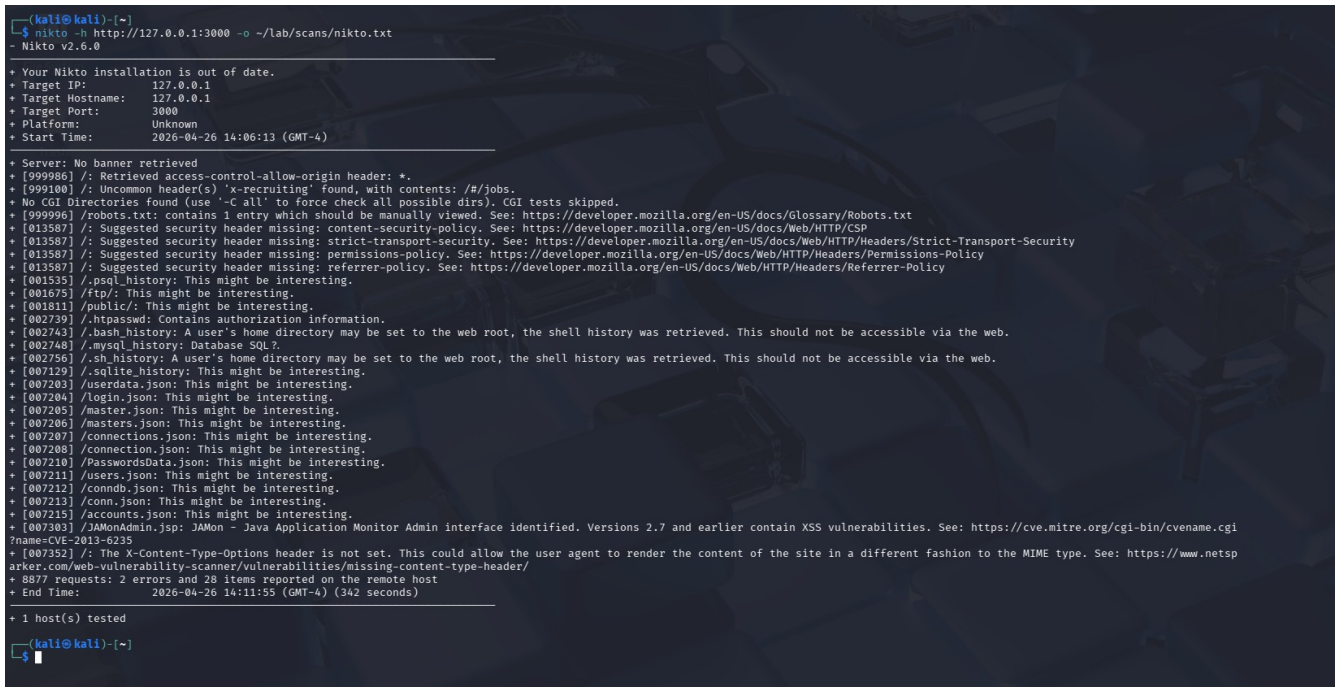
03: Port Scan (nmap -sV)

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 3000 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 13:49 EDT
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00042s latency).

PORT     STATE SERVICE VERSION
3000/tcp open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3000-TCP:V=7.95%I=7%D=4/26%Time=69EE502C%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,101B9,"HTTP/1\.1\x20200\x20OK\r\nAccess-Control-Allow-Origin:\
SF:x20\*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAME
SF:ORIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/j
SF:obs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=
SF:0\r\nLast-Modified:\x20Sun,\x2026\x20Apr\x202026\x2017:39:10\x20GMT\r\n
SF:ETag:\x20W/\"124fa-19dcadfb027\"\r\nContent-Type:\x20text/html;\x20char
SF:set=UTF-8\r\nContent-Length:\x2075002\r\nVary:\x20Accept-Encoding\r\nDa
SF:te:\x20Sun,\x2026\x20Apr\x202026\x2017:49:32\x20GMT\r\nConnection:\x20c
SF:lose\r\n\r\n<!--\n\x20\x20~\x20Copyright\x20(c)\x202014-2026\x20Bjoer
SF:n\x20Kimminich\x20&\x20the\x20OWASP\x20Juice\x20Shop\x20contributors\.\
SF:n\x20\x20~\x20SPDX-License-Identifier:\x20MIT\n\x20\x20-->\n\n<!doctype
SF:\x20html>\n<html\x20lang=\"en\"\x20data-beasties-container>\n<head>\n\x
SF:20\x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>OWASP\x20Juice\x20Sho
SF:p</title>\n\x20\x20<meta\x20name=\"description\"\x20content=\"Probably\
SF:x20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20
SF:application\">\n\x20\x20<meta\x20name=\"viewport\"\x20content=\"width=d
SF:evice-width,\x20initial-scale=1\">\n\x20\x20<link\x20id=\"favicon\"\x20
SF:rel=\"icon\"\x20")%r(Help,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nCon
SF:nection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1\.1\x20400\x20Bad\x20Reques
SF:t\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1\.1\x20204\
SF:x20No\x20Content\r\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Contro
SF:l-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-C
SF:ontrol-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Sun,\x2026\x
SF:20Apr\x202026\x2017:49:32\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RT
SF:SPRequest,EA,"HTTP/1\.1\x20204\x20No\x20Content\r\nAccess-Control-Allow
SF:-Origin:\x20\*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,P
SF:OST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length
SF::\x200\r\nDate:\x20Sun,\x2026\x20Apr\x202026\x2017:49:32\x20GMT\r\nConn
SF:ection:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.71 seconds
```

04: Juice Shop Homepage

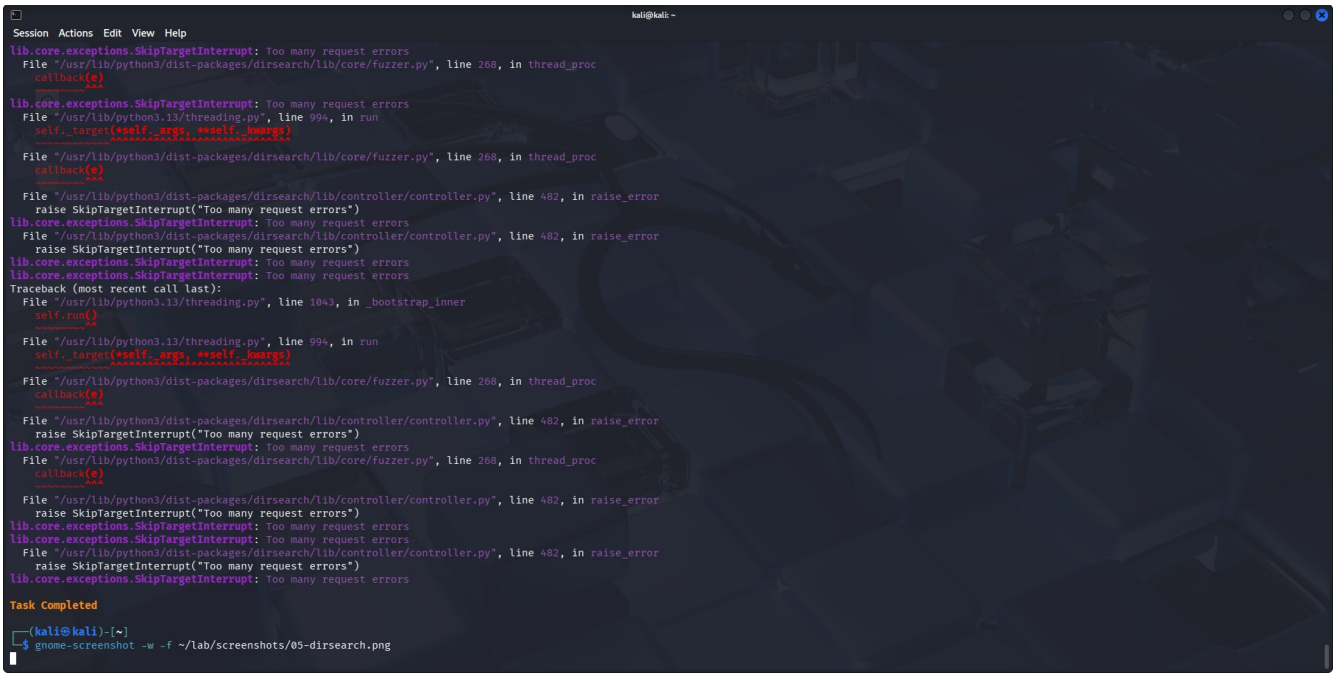


05: Nikto Scan Output



```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://127.0.0.1:3000 -o ~/lab/scans/nikto.txt
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          127.0.0.1
+ Target Hostname:    127.0.0.1
+ Target Port:        3000
+ Platform:           Unknown
+ Start Time:         2026-04-26 14:06:13 (GMT-4)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [001535] /.psql_history: This might be interesting.
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002748] /.mysql_history: Database SQL ?.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007129] /.sqlite_history: This might be interesting.
+ [007203] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /PasswordsData.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /conndb.json: This might be interesting.
+ [007213] /conn.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007303] /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://cve.mitre.org/cgi-bin/cvename.cgi
?name=CVE-2013-6235
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsp
arker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8877 requests: 2 errors and 28 items reported on the remote host
+ End Time:           2026-04-26 14:11:55 (GMT-4) (342 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(kali㉿kali)-[~]
└─$
```

06: Dirsearch Scan Output



Conclusion

The OWASP Juice Shop application contains multiple security weaknesses that need to be addressed. High priority issues like exposed shell history files should be fixed immediately. Missing security headers should be added to prevent common web attacks. Regular vulnerability assessments should be conducted to maintain security posture.

Recommendations

1. Remove shell history files from web root.
2. Restrict access to /ftp: and /public: directories.
3. Add security headers (CSP, HSTS, X-Frame-Options).
4. Review /robots.txt for sensitive information.
5. Keep all software updated.